微信小程序账号与密钥维护清单

> 注：目标：从开发到运维，明确所有需要掌握和维护的账号、密钥、证书与权限信息，避免后续无法接手。

术语先统一（避免混淆）

- 小程序侧常用：`AppID`、`AppSecret`
- 微信支付常用：`商户号(mchid)`、`API v3 Key`、`商户私钥`、`证书序列号`
- `appkey/appsecret` 在不同平台含义不同。建议在台账中记录「来源系统 + 字段原名」。

一、微信生态必须有的账号/凭证

1) 微信公众平台（小程序）账号

- 管理员微信号（超级关键）
- 运营者/开发者微信号（成员管理）
- 小程序 `AppID`
- 小程序 `AppSecret`（仅后端保存）

2) 小程序发布相关权限

- 提审发布权限人员账号
- 体验版成员账号（测试人员）

3) （可选）微信开放平台账号

- 仅在需要 UnionID、绑定多个应用时使用

二、微信支付必须有的账号/凭证（做支付必备）

1) 微信支付商户平台账号

- 超级管理员账号（法人相关）
- 财务/运营/开发操作员账号（分权）

2) 支付核心参数

- `mchid`（商户号）
- 绑定的小程序 `AppID`
- `API v3 Key`
- 商户私钥文件（通常为 `apiclient_key.pem`）
- 商户证书序列号

- 微信支付平台证书/平台公钥 ID（验签用）
- （如使用 V2 接口）`APIv2 Key`

3) 支付运维信息

- 支付回调 URL 配置权限
- 退款/分账权限账号
- 对账单下载权限账号

注：注意：支付密钥不得放在小程序前端，只能保存在后端服务。

三、后端与基础设施账号

1) 云厂商账号（阿里云/腾讯云/华为云等）

- 主账号（仅保管）
- 子账号（最小权限）

2) 服务器/容器

- SSH 密钥或堡垒机账号
- 生产环境登录权限账号

3) 数据库

- 管理员账号（root/dba）
- 业务读写账号
- 只读账号（报表/查询）
- 备份账号（备份恢复专用）

4) 缓存/队列/对象存储

- Redis 账号密码
- MQ 账号
- OSS/COS/S3 的 AK/SK 或角色权限

5) 配置与密钥管理

- Secret Manager/Vault 账号
- CI/CD 注入凭证权限

四、域名与合规相关账号

- 域名注册商账号
- DNS 解析平台账号

- SSL 证书平台账号
- ICP 备案账号（中国大陆服务器必备）
- CDN/WAF 账号（如使用）

五、研发协作与发布账号

- 代码仓库账号（GitHub/GitLab/Gitee）
- 至少 2 人拥有 Owner/Admin 权限
- CI/CD 账号
- 制品仓库账号（Docker Registry、私有 NPM/PyPI）

六、第三方服务账号（按业务选）

- 短信平台（阿里云短信/腾讯云短信）
- 邮件服务（企业邮箱 SMTP、SendGrid 等）
- 地图定位（腾讯地图 Key）
- OCR/实名认证/风控服务
- 监控告警（Sentry、云监控、企业微信机器人）

你至少要亲自掌握的核心 10 项

1. 公众平台超级管理员微信号
2. 小程序 `AppID/AppSecret`
3. 微信支付超级管理员 + `mchid`
4. 支付 `API v3 Key` + 商户私钥 + 证书序列号
5. 云厂商主账号恢复方式
6. 域名注册商主账号
7. 代码仓库 Owner 权限账号
8. 生产数据库管理员账号与备份恢复权限
9. 密码管理器主账号与恢复码
10. 告警系统主账号（故障时第一时间通知）

维护建议（可直接执行）

- 建立《账号与密钥台账》：系统名、用途、账号、2FA、负责人、到期日、重置方式
- 所有密钥统一放密码管理器（1Password/Bitwarden）
- 前后端严格分离：密钥仅后端保存
- 高危密钥定期轮换（建议每 90 天）
- 每季度执行一次离职交接演练和灾难恢复演练